Esame Modulo 5

Security Operation & Incident Response

1. Analisi degli Incidenti di Sicurezza

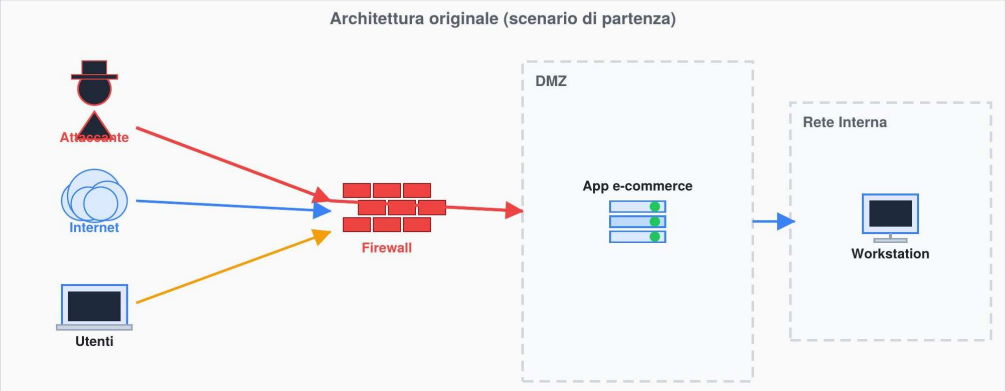
Incident – SQL Injection su applicazione e-commerce

L'applicazione e-commerce pubblica è vulnerabile a SQL Injection. Un attaccante esterno ha sfruttato tale vulnerabilità per accedere e modificare i dati del database.

Classificazione: Triade CIA

Proprietà	Impatto	Motivazione
Riservatezza	ALTA	Accesso non autorizzato ai dati degli utenti e alle informazioni di pagamento.
Integrità	ALTA	Modifica dei dati nel DB (prezzi, ordini, dati utente).
Disponibilità	MEDIA	Potenziale interruzione del servizio tramite query distruttive (DROP, DELETE).

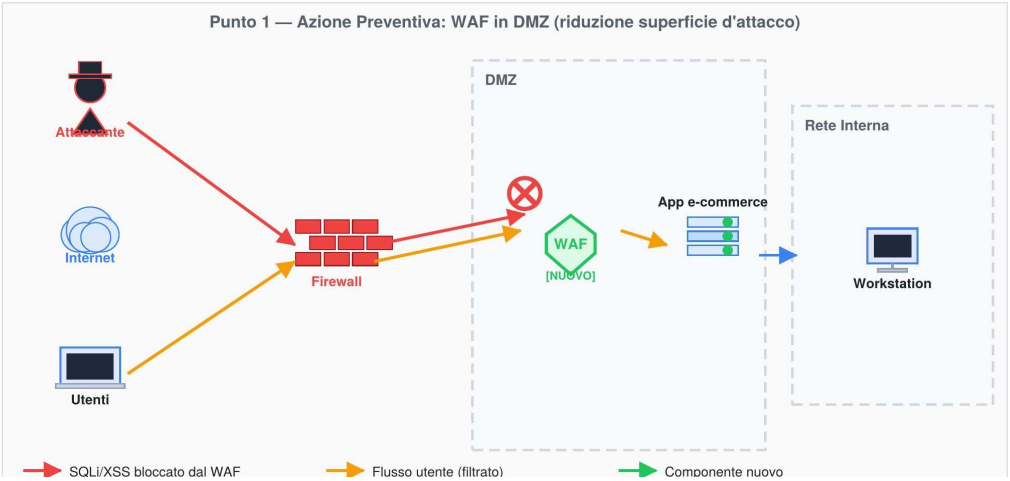
Architettura di Rete Originale



Contromisure Preventive

Contromisura	Tipo	Descrizione
WAF (Web Application Firewall)	Preventiva	Filtra le richieste HTTP malevole prima che raggiungano l'applicazione.
Prepared Statements / ORM	Preventiva	Eliminano la possibilità di SQL Injection separando codice e dati.
Principio del minimo privilegio	Preventiva	L'utente DB dell'app ha solo i permessi strettamente necessari.
Input validation & sanitization	Preventiva	Validazione lato server di tutti gli input utente.
SIEM / Logging	Rilevamento	Monitoraggio e correlazione degli eventi per rilevare pattern anomali.
Output Encoding	Preventiva	Codifica l'output HTML prima del rendering, il browser interpreta i dati come testo, non come script eseguibili. Contromisura principale contro XSS.
CSP (Content Security Policy)	Preventiva	Header HTTP che indica al browser da quali sorgenti caricare script e stili. Blocca l'esecuzione di script iniettati provenienti da origini non autorizzate.

Architettura con WAF



2. Impatti sul Business: Attacco DDoS

Calcolo dell'Impatto Economico

Un attacco DDoS di 10 minuti, con un fatturato medio di 1.500 €/min, genera le seguenti perdite:

Parametro	Valore	Calcolo / Note
Asset Value (AV)	15.000 €	Fatturato perso per 10 minuti di downtime: 1.500 €/min × 10 min.
Exposure Factor (EF)	100%	In caso di DDoS il servizio è completamente irraggiungibile.
Single Loss Expectancy (SLE)	15.000 €	AV × EF = 15.000 × 1,0
Annual Rate of Occurrence (ARO)	2	Frequenza stimata: 2 attacchi/anno.
Annual Loss Expectancy (ALE)	30.000 €	SLE × ARO = 15.000 × 2

Un ALE di 30.000 €/anno giustifica economicamente investimenti in protezione Anti-DDoS.

Strategie di Gestione del Rischio DDoS

Strategia	Descrizione	Esempio applicato
Riduzione	Abbassare probabilità e impatto dell'evento.	CDN Anti-DDoS + NGFW con IPS: riduce drasticamente la probabilità di successo dell'attacco.
Accettazione	Accettare il rischio residuo se il costo di mitigazione supera il danno.	Accettare attacchi brevi (minori di 1 min) se il costo di mitigarli è maggiore
Assicurazione	Trasferire il rischio finanziario tramite polizza cyber.	Stipulare una cyber insurance che copra il fatturato perso in caso di downtime prolungato.

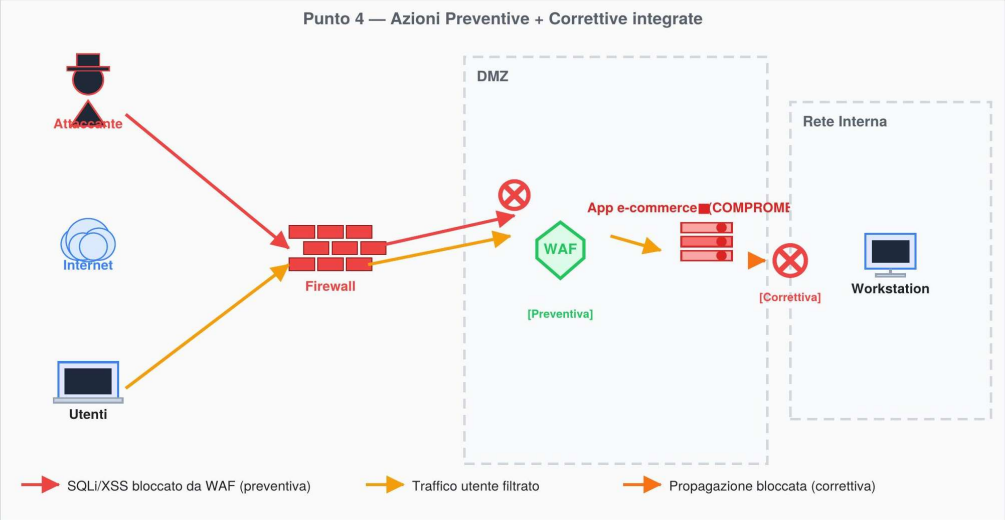
Azioni Preventive Applicabili

Contromisura	Tipo	Descrizione
CDN Anti-DDoS (Cloudflare)	Preventiva — Rete	Assorbe il traffico volumetrico prima che raggiunga l'infrastruttura.
Rate Limiting / IP Filtering	Preventiva — Rete	Limita le richieste per IP/range; blocca sorgenti note di botnet tramite blacklist.
NG Firewall con IPS	Preventiva Perimetro	Ispezione profonda dei pacchetti; rileva e blocca pattern DDoS volumetrici e applicativi.

3. Soluzione Integrata

La soluzione integrata combina la misura preventiva con la misura correttiva

HLD — Architettura integrata (preventiva + correttiva)



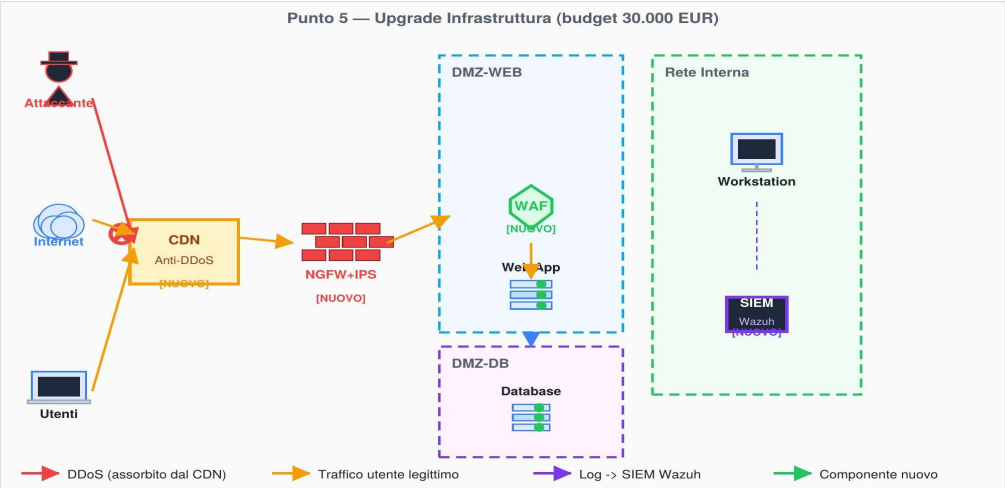
Confronto Misure

Tipo	Misura	Quando agisce	Efficacia
Preventiva	WAF	Prima dell'incidente	Blocca attacchi noti (SQLi, XSS)
Correttiva	Rete Quarantena	Durante/dopo incidente	Limita il danno, isola la minaccia
Rilevamento	SIEM / IDS	Durante l'incidente	Rileva anomalie e attiva alerting
Ripristino	Backup & Restore	Dopo incidente	Ripristina operatività normale

4. Proposta di Upgrade dell'Infrastruttura

Architettura Post-Upgrade

L'upgrade proposto introduce CDN, Next-Generation Firewall, separazione della DMZ in due zone (WEB e DB), e un SIEM centralizzato. Budget disponibile: 27.100 €.



Piano di Investimento Dettagliato (Budget: 27.100 €)

Componente	Tipo	Costo	Giustificazione
CDN (Cloud-based)	Preventiva – DDoS	3.600 €/anno	Protezione da attacchi volumetrici, miglioramento performance.
NGFW (Next-Gen Firewall)	Preventiva – Perimetro	8.000 € una tantum	Sostituzione firewall legacy. DPI, IPS, Application Awareness.
WAF (upgrade)	Preventiva – Applicativa	3.000 €/anno	Già presente; aggiornamento firme e regole custom.
Separazione DMZ-WEB / DMZ-DB	Architetturale	2.500 € una tantum	Segmentazione rete: il DB non è direttamente accessibile dalla DMZ-WEB.
SIEM (Security Information & Event Mgmt)	Rilevamento	6.000 €/anno	Correlazione log, alerting real-time, dashboard SOC.
Formazione e Penetration Testing	Preventiva – Umana	4.000 €/anno	Test annuale + formazione sviluppatori su OWASP Top 10.
TOTALE PRIMO ANNO		**27.100 €**	Include costi una tantum (NGFW + segmentazione) + costi ricorrenti annui.

4.3 ROI e Analisi Costi-Benefici

Scenario	ALE (perdita annua attesa)	Costo contromisure	Risparmio netto
Senza upgrade	15.000 €	—	—
Con upgrade (anno 1)	~1.500 €	27.100 €	–13.600 € (investimento iniziale)
Con upgrade (anni 2+)	~1.500 €	16.600 €/anno	+13.400 €/anno risparmio